



SÃO
PAULO
TECH
SCHOOL

Segurança da Informação

Sprint 2 - Aula 06

I.A. na Defesa Cibernética

Pedro Neves

Pedro.neves@sptech.school

Objetivos da Sprint

- **I.A. como vetor de ataque**
- **I.A. na defesa cibernética**
- **Governança da I.A.**
- **Segurança da Infraestrutura e Cloud**

01 - Conexão com aula 05:

Na **Aula 05** examinamos a IA como **vetor de ataque**: deepfakes, phishing gerado por LLM, malware polimórfico e prompt injection. Hoje viramos a perspectiva: a mesma tecnologia que equipa o atacante, como uma grande **ferramenta de defesa**.

IA do Atacante

16% das violações já envolveram IA do atacante, sendo 37% via phishing gerado por IA e deepfakes. O custo médio de uma violação com IA do atacante salta para **~US\$ 6 milhões** — muito acima da média global.

Fonte: IBM Cost of a Data Breach 2025

IA da Defesa

Organizações que adotam IA e automação na defesa economizam, em média, **US\$ 1,9 milhão por violação**. A diferença é estrutural.

Fonte: IBM Cost of a Data Breach 2025

-  **A corrida armamentista cibernética é real:** defesa e ataque evoluem juntos, impulsionados pela mesma tecnologia. Quem não adota IA na defesa fica progressivamente para trás.

02 - IA como Aliada: O SOC Alimentado por ML

O **Security Operations Center (SOC)** é o centro nervoso da defesa corporativa: monitora, detecta, analisa e responde a incidentes de segurança em tempo real. O problema histórico do SOC tradicional é o chamado **alert fatigue** — equipes recebem dezenas de milhares de alertas por dia, a maioria falsos positivos, levando à dessensibilização e à **fadiga operacional**.

A IA entra para resolver exatamente esse gargalo, **atuando em quatro frentes**:

Triagem

Prioriza alertas por nível de risco real, eliminando ruído.

Correlação

Conecta eventos dispersos em diferentes fontes e sistemas.

Priorização

Pontua e ordena incidentes por impacto potencial ao negócio.

Automação

Executa respostas padronizadas sem intervenção humana.

60%

Alerta ignorado foi crítico

Das equipes de segurança relataram que um alerta ignorado se revelou um incidente crítico com impacto direto na postura de segurança. *(Prophet Security, 2025)*

90%+

Alertas rotineiros resolvidos por IA

Previsão para 2026: a IA resolve a grande maioria dos alertas de baixa complexidade, deslocando o analista para supervisão e revisão. *(Swimlane, 2026)*

 O analista humano não é substituído — **é transferido ou elevado, para outro nível.**

Ele passa a tomar decisões complexas, supervisionar agentes e avaliar contexto de negócio que a IA não alcança.

02 - IA como Aliada: Quatro camadas

O SOC moderno não surgiu do dia para a noite. Cada geração resolveu os problemas da anterior — e criou novos desafios que a próxima precisou endereçar.

Camada 1 - SIEM Tradicional

Correlação de logs com **regras manuais** escritas por analistas. Alta taxa de falsos positivos. Volume crescente tornava a gestão insustentável. Ferramentas pioneiras: ArcSight, early Splunk.

1

2

Camada 2 - SOAR

Introdução de **automação de playbooks** para respostas padronizadas. Redução do tempo de resposta de horas para minutos. As regras continuavam manuais, mas a execução era automatizada.

Camada 3 - ML e UEBA

Deteção comportamental substituindo parcialmente as regras estáticas. Os modelos aprendem o "normal" e sinalizam desvios. Surgimento de plataformas de User and Entity Behavior Analytics.

3

4

Camada 4 - IA Generativa e Agentic AI

Copilotos e agentes autônomos integrados ao SOC. O agente investiga, correlaciona, executa contenção e documenta — com supervisão humana. Hoje: Splunk ES, Microsoft Sentinel, Exabeam integram SIEM + SOAR + UEBA + IA.

📌 Hoje, muitas plataformas entregam todas as quatro camadas em uma única plataforma de SOC consolidada.

03 - Detecção de Anomalias em Tempo Real — Como Funciona

A premissa é simples e poderosa: a IA aprende o que é "**normal**" no ambiente — o baseline — e sinaliza em tempo real qualquer comportamento que se desvie desse padrão. Mas implementar isso de forma precisa é um desafio de engenharia de ML.

Técnicas Utilizadas

ML Supervisionado

Classifica eventos com base em dados rotulados (benigno/malicioso). Exige dataset de treinamento de qualidade. Alta precisão quando bem calibrado.

ML Não Supervisionado

Clustering e detecção de outliers sem labels. Ideal para descobrir ameaças desconhecidas. Modelos como Isolation Forest, Autoencoder e k-means.

Análise Estatística

Desvio padrão, médias móveis e modelos de séries temporais para detectar variações significativas em métricas de comportamento.

Exemplos de Anomalias Detectadas

- **Login fora do horário habitual** — usuário que sempre acessa das 8h às 18h aparece às 3h da manhã de um IP diferente.
- **Volume de dados exfiltrado** — transferência de 50 GB em uma única sessão quando a média histórica é 200 MB.
- **Acesso a sistema nunca utilizado** — conta do financeiro acessando servidor de produção do TMS pela primeira vez.
- **Horário atípico de transferência bancária** — transação de alto valor iniciada fora da janela operacional aprovada.

 A detecção de anomalias é a **base do UEBA** e do modelo de detecção de ameaças internas. Sem um baseline sólido, o modelo não tem referência para definir o que é anômalo.

04 – UEBA (User and Entity Behavior Analytics)

O **UEBA (User and Entity Behavior Analytics)** vai além da detecção de anomalias genérica: ele cria um **baseline comportamental individual** para cada usuário E para cada entidade no ambiente — dispositivos, contas de serviço, aplicações, endereços IP — e rastreia continuamente os desvios desse perfil personalizado.

O diferencial do UEBA é detectar o que **regras estáticas nunca veriam**: não é a ação em si que é suspeita, mas o desvio do padrão histórico daquele indivíduo específico.

Casos Clássicos de Detecção por UEBA



Funcionário prestes a sair da empresa

Começa a baixar bases de dados inteiras, exportar contatos de clientes e acessar documentos que nunca havia acessado — em volume e frequência atípicos para seu perfil.



Conta de serviço com comportamento anômalo

Uma conta de integração entre sistemas começa a fazer logins interativos, acessar diretórios fora do escopo e executar comandos atípicos — sinal claro de comprometimento.



Acesso a dados nunca acessados

Usuário de um departamento acessa repositórios de outro departamento, cruzando silos de dados de forma incomum para seu histórico.

Detecção de Anomalias – Exemplo:

Imagine o cenário: os sistemas de uma transportadora de médio porte registra o seguinte conjunto de eventos numa mesma sessão:

- Usuário do setor **financeiro** faz login no ERP às **3h17 da manhã**
- O acesso é originado de um **dispositivo nunca visto antes** no ambiente
- O mesmo usuário baixa **relatórios completos de rotas de clientes no TMS**
- O volume exportado é muito **maior** do que a média histórica desse usuário

A IA correlaciona todos esses sinais em milissegundos e gera um **alerta de alto risco** antes que o dano seja consumado.

Sem ML, esse padrão provavelmente só seria percebido no dia seguinte.



A correlação de eventos ágil combinada com análise de comportamento é crucial para detecção e resposta eficiente aos incidentes.

05 - Modelos de Classificação para Malware

A detecção de malware passou por uma **evolução radical** nas últimas décadas, impulsionada diretamente pela corrida armamentista entre atacantes e defensores. Compreender essa evolução é fundamental para entender por que o ML é hoje indispensável.



-  **Assinaturas**
Hash e ameaças conhecidas
-  **Heurísticas**
Regras e padrões comportamentais
-  **Machine Learning**
Estático, dinâmico e runtime

Ferramentas Líderes



Como o ML Classifica Malware

Os modelos de ML analisam o arquivo e o comportamento em três dimensões complementares:

Análise Estática
Estrutura do binário, strings embutidas, imports de bibliotecas, entropia do arquivo — sem executar o código.

Análise Dinâmica
Execução em sandbox isolada: quais processos são criados, quais chamadas de API são feitas, quais arquivos são modificados.

Análise em Runtime
Monitoramento comportamental em produção: o agente no endpoint observa o comportamento em tempo real e bloqueia se necessário.

☐ **COM ML:**
detecta malware desconhecido (zero-day) e variantes polimórficas — exatamente o que a IA do atacante gera.
Sem ML:
a defesa fica sempre um passo atrás.

05 - Classificação de Malware - Exemplo

O Cenário: Ransomware Desconhecido no Centro de Distribuição

Um ransomware de nova geração — **sem assinatura conhecida**, gerado com apoio de IA generativa (como vimos na Aula 05) — é introduzido em um terminal de um centro de distribuição por meio de um anexo malicioso. A proteção baseada em assinaturas não o reconhece. Mas o modelo de ML do agente no endpoint observa o comportamento:

- **Escrita em massa de arquivos** — centenas de arquivos renomeados com extensão desconhecida em segundos.
- **Chamadas a APIs de criptografia** — uso intensivo de CryptEncrypt e funções nativas de cifragem do sistema operacional.
- **Tentativas de acesso a shares de rede** — propagação horizontal buscando mapeamentos de rede compartilhados.
- **Bloqueio em runtime** — o agente interrompe a execução e isola o processo antes que o dano se propague.

O Impacto no Contexto Logístico

Sem essa proteção comportamental, um ransomware que paralisasse os sistemas causaria:

- Interrupção total do planejamento de rotas e despacho
- Perda de visibilidade sobre a localização da frota
- Impossibilidade de controle de estoque nos CDs
- Impacto em clientes, contratos e SLAs operacionais
- Pressão por pagamento de resgate para retomar operações

⚠ A proteção comportamental por ML é a única defesa eficaz atualmente contra variantes polimórficas geradas por IA — assinaturas não servem aqui.

6 - SOAR (Security Orchestration, Automation and Response)

O **SOAR** nasceu para resolver o problema que o SIEM não resolvia sozinho: detectar é necessário, mas **responder com velocidade e consistência** é o que determina o impacto do incidente. O SOAR orquestra ferramentas de segurança heterogêneas, automatiza playbooks de resposta e gerencia o ciclo de vida completo do caso de incidente.

Ferramentas SOAR do Mercado

Splunk SOAR

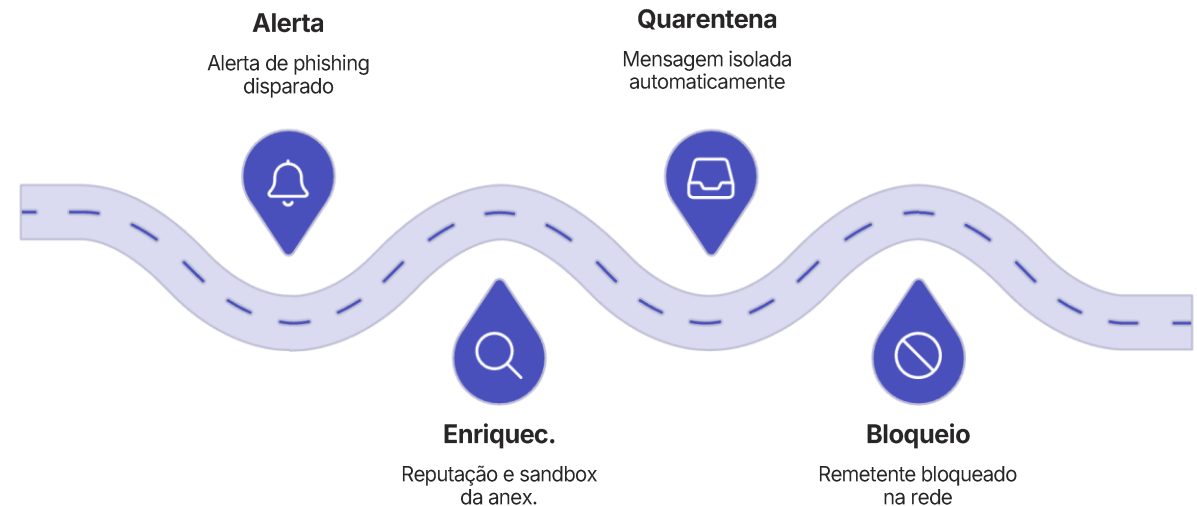
IBM QRadar SOAR

Palo Alto Cortex
XSOAR

Swimlane

Microsoft Sentinel

Playbook Típico de Resposta a Phishing



O benefício central do SOAR é a **resposta veloz**, com consistência e sem depender da disponibilidade de um analista.

Cada passo é auditável e documentado automaticamente no caso de incidente.

6 - SOAR com IA

A nova geração de SOAR vai além da automação de playbooks fixos: incorpora **IA generativa e agentes autônomos** capazes de avaliar contexto do incidente, tomar decisões adaptativas e executar ações de contenção - com supervisão humana nos pontos críticos.

Plataformas de SOC com Agentic AI

CrowdStrike Charlotte AI — Agentic SOAR

Agente autônomo que investiga alertas, correlaciona telemetria do Falcon e executa contenção aprovada sem intervenção manual.

Exabeam Copilot

IA generativa integrada ao SIEM/UEBA que explica Smart Timelines em linguagem natural e sugere próximos passos da investigação.

Prophet Security

Plataforma agentic focada em triagem autônoma — o agente investiga e classifica alertas, reduzindo drasticamente a fila do analista.

Stellar Cyber + Splunk AI

Plataformas com AI Copilot integrado para geração de consultas, sumarização de incidentes e recomendações contextuais.

Como o Agente Atua

1. Recebe o alerta

O agente é acionado por um alerta de alta prioridade no SIEM e inicia a investigação autonomamente.

2. Correlaciona contexto

Agrega telemetria de múltiplas fontes: logs, endpoint, identidade, rede — constrói o timeline do incidente.

3. Executa contenção aprovada

Isola o endpoint, bloqueia a conta, revoga tokens — ações pré-aprovadas dentro do escopo de automação.

4. Documenta e escala

Registra todas as ações, gera relatório do incidente e escala para o analista humano nos pontos ambíguos.



Discussão:

Até onde delegar resposta autônoma a um agente de IA?

Quais ações exigem sempre aprovação humana?

07 - IA Generativa no SOC - Copilotos e Assistentes



- ❗ Copilotos de IA no SOC não substituem os analistas - eles reduzem a **curva de aprendizado** e aceleram a investigação para analistas de todos os níveis.

Casos de Uso Práticos — Splunk AI e Plataformas Similares



Sumarização de Incidentes

O copiloto lê o timeline completo do ataque — dezenas de eventos correlacionados — e produz um resumo em linguagem natural para o analista em segundos. O que levaria 30 minutos de leitura é condensado em 3 parágrafos acionáveis.



Geração de Consultas de Busca

O analista descreve em português o que quer investigar ("mostre todos os logins de usuários privilegiados fora do horário comercial na última semana") e o copiloto gera a query SPL, KQL ou equivalente automaticamente.



Onboarding de Novos Analistas

Analistas juniores recebem explicações contextuais sobre alertas complexos — o copiloto explica o que significa cada evento, sugere hipóteses e recomenda a primeira ação de investigação, reduzindo meses da curva de aprendizado.



Relatórios Pós-Incidente

Ao encerrar um caso, o copiloto gera automaticamente o rascunho do relatório pós-incidente com timeline, causa raiz, ações tomadas e recomendações de melhoria — reduzindo horas de trabalho de documentação.

08 - Limites da IA na Defesa

A IA defensiva é poderosa, mas **não é infalível**. Compreender seus limites é tão importante quanto conhecer suas capacidades.

Os Dois Tipos de Erro dos Modelos

Falso Positivo

O modelo alerta para algo que **não é uma ameaça**. Volume excessivo de falsos positivos gera alert fatigue — analistas param de investigar alertas de baixa prioridade, criando pontos cegos perigosos. Custo: tempo desperdiçado e dessensibilização da equipe.

Falso Negativo

O modelo **não detecta uma ameaça real**. É o erro mais perigoso — a organização acredita estar protegida enquanto o atacante age. Pode resultar em comprometimento prolongado sem detecção (dwell time elevado).

O tuning de modelos exige equilíbrio permanente entre **precisão** (não disparar à toa) e **recall** (não deixar passar ameaças reais). Não há configuração perfeita — é um ajuste contínuo baseado no ambiente específico.



A supervisão humana continua essencial. A IA prioriza e filtra o ruído — mas o humano decide. Delegar 100% da triagem a um modelo sem revisão é tão perigoso quanto não ter IA: o contexto de negócio, o julgamento ético e a responsabilidade pela decisão permanecem com o analista.

Boas Práticas de Tuning

- Ajuste iterativo dos limiares de alerta com base em feedback dos analistas
- Whitelist de comportamentos legítimos conhecidos (ex.: backups noturnos)
- Revisão periódica de alertas fechados como falso positivo
- Métricas de qualidade do modelo: taxa de FP, tempo de detecção, MTTD e MTTR

09 – Adversarial ML: Ataques aos Modelos Defensivos

A mesma IA que defende pode ser **atacada diretamente**. O campo do Adversarial Machine Learning estuda como os atacantes identificam e exploram as fraquezas dos modelos de defesa. Em 2025, o NIST publicou a taxonomia oficial, que classifica esses ataques em três categorias fundamentais.

Evasão (Evasion)

O atacante introduz **perturbações sutis na entrada** durante a inferência do modelo para enganá-lo, sem alterar o modelo em si. Exemplo: alterar características de pacotes de rede (tamanho, timing, ordem) de forma pouco perceptível. É o ataque mais comum em produção.

Envenenamento (Poisoning)

O atacante **contamina os dados de treinamento** para corromper o modelo antes de ele ser implantado. Exemplo: injetar amostras de malware cuidadosamente rotuladas como "benignas" no dataset de treinamento do classificador — o modelo aprende que aquele padrão é inofensivo. O efeito persiste silenciosamente após o deploy.

Backdoor

Inserção de um **gatilho oculto** no modelo que ativa comportamento malicioso quando um padrão específico está presente na entrada. O modelo se comporta normalmente em todos os outros casos, tornando a detecção extremamente difícil. Também chamado de Trojan Attack em modelos de ML.



O atacante estuda o modelo defensivo e o contorna sistematicamente. Quanto mais previsível e estático o modelo, mais vulnerável ele é.

A defesa precisa evoluir continuamente — assim como o ataque.

09 Adversarial ML - Mitigações

- **Adversarial Training**
treinar o modelo com exemplos adversários gerados deliberadamente, tornando-o mais robusto a perturbações.
- **Validação e Higiene do Dataset**
auditar o pipeline de dados de treinamento, controlar o acesso e monitorar a integridade das amostras rotuladas.
- **Monitoramento de Drift do Modelo**
detectar quando o comportamento do modelo muda inesperadamente em produção, sinalizando possível envenenamento ou mudança de distribuição.
- **Defesa em Profundidade**
nunca depender de uma única camada de ML. Combinar múltiplos modelos, regras estáticas, análise humana e controles compensatórios.
- **Revisão Humana nos Pontos Críticos**
para decisões de alto impacto, exigir sempre validação humana antes da ação, independentemente da confiança do modelo.

O Cenário de Mercado – IA na defesa Cibernética

Dados verificados de 2025-2026 que fundamentam a urgência da adoção de IA na defesa cibernética corporativa.

US\$4,44M

Custo médio de violação

Queda de 9% vs US\$ 4,88 mi em 2024.

Mas violações com IA do atacante chegam a ~US\$ 6 mi. *(IBM 2025)*

+89%

Ataques AI-enabled

Crescimento ano a ano (2025 vs 2024)
de ataques de adversários habilitados por IA.
(CrowdStrike 2026)

29min

Breakout time médio

Tempo médio para o atacante se mover lateralmente após acesso inicial.
O mais rápido registrado: 27 segundos. *(CrowdStrike 2026)*

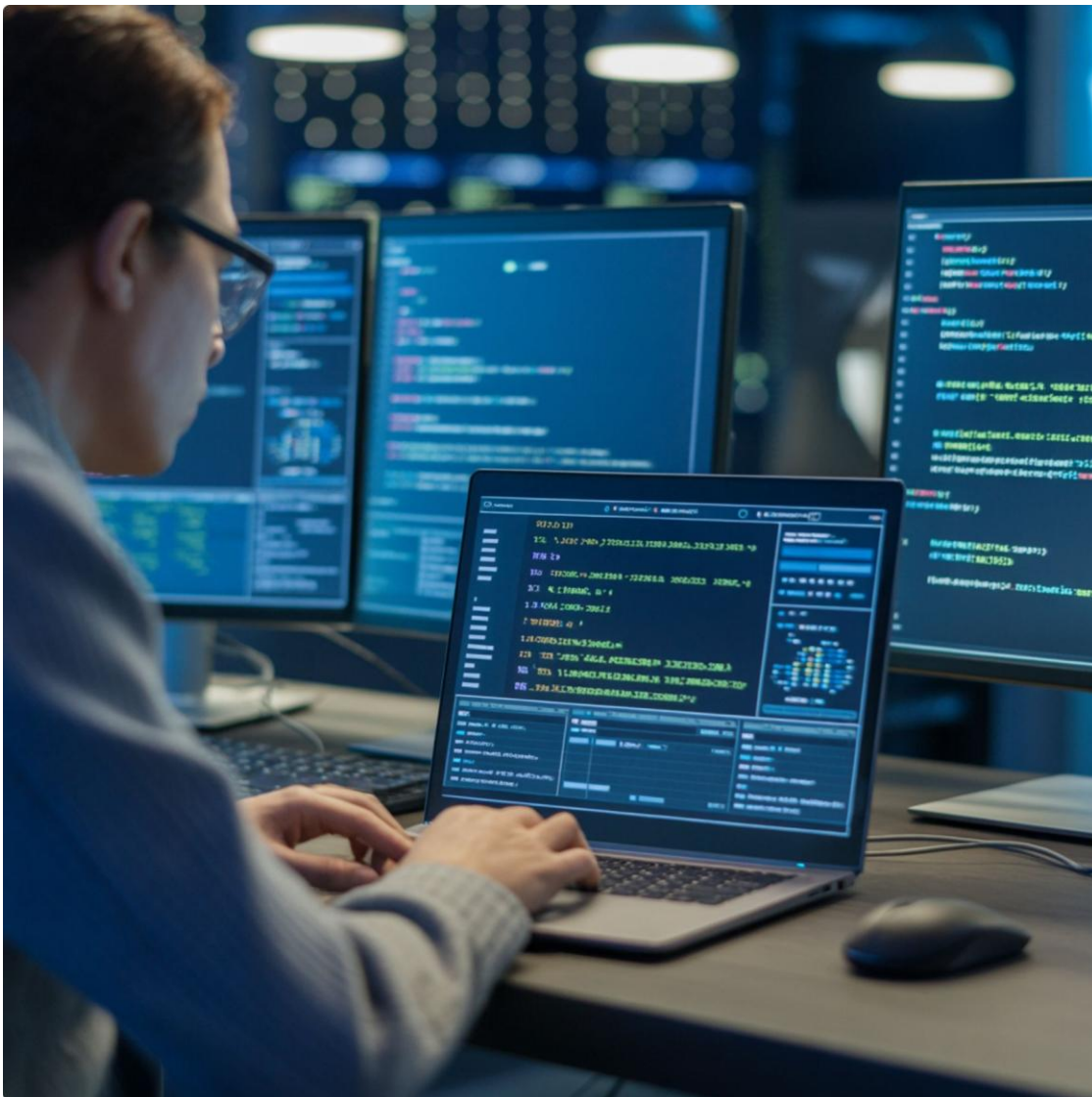
Mensagem-chave: a defesa com IA não é mais opcional

Com breakout time de 29 minutos em média, a resposta humana manual simplesmente não é suficientemente rápida.

A previsão da Swimlane para 2026 aponta ainda que **certificações ISO 42001** e o uso de **LLMs privados** se tornarão mandatórios para auditabilidade e privacidade nos SOCs corporativos — tema que conecta diretamente com a próxima aula.

10 – Atividade prática

ATIVIDADE CONDENSADA - PODE SE ESTENDER



O Cenário

Vocês recebem um **dataset simulado de logs** de acesso de uma transportadora de médio porte, contendo registros de autenticação, tráfego de rede e alertas do SIEM ao longo de 72 horas. O dataset foi construído para conter padrões anômalos deliberados — alguns óbvios, outros sutis.

O Que Vocês Devem Identificar

Padrões anômalos

Riscos associados

Recomendações

Entregável

Relatório com:

- (1) padrões anômalos identificados;
- (2) nível de risco associado a cada um;
- (3) recomendação de resposta — conectando com os conceitos de UEBA e SOAR vistos hoje.

Encerramento — Síntese e Ponte para a Aula 07

O Que Vimos Hoje

SOC com ML

A IA transforma o centro de operações: tria, correlaciona e prioriza com velocidade humana impossível.

UEBA

Perfil individual de usuários e entidades — detecta ameaças internas e contas comprometidas.

SOAR + Agentic AI

Automação de playbooks e agentes autônomos elevam o analista a supervisor estratégico.

Deteccção de Anomalias

Baseline + desvio em tempo real: a base de toda defesa comportamental moderna.

Classificação de Malware

ML detecta zero-days e variantes polimórficas sem depender de assinaturas.

Limites e Adversarial ML

Falsos positivos, alert fatigue, evasão e envenenamento — a supervisão humana é insubstituível.

A Pergunta que Abre a Próxima Aula

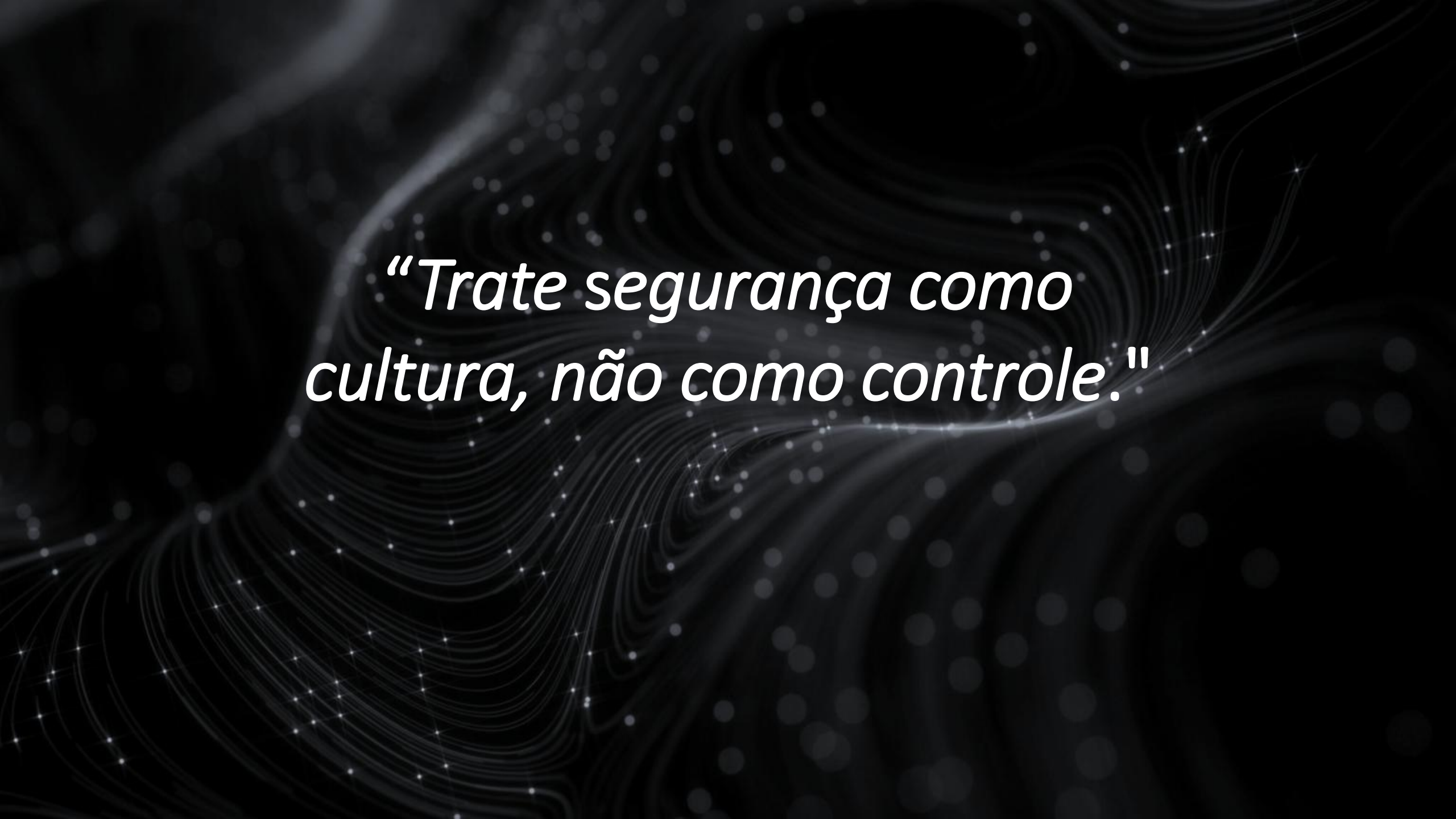
Se a IA defende e a IA ataca — quem governa a IA? E quem responde quando ela erra?

Aula 07: Governança de IA e Aspectos Regulatórios

- Políticas de uso aceitável de IA em ambientes corporativos
- EU AI Act — implicações para sistemas de segurança
- LGPD, art. 20 e art. 42 — decisões automatizadas e responsabilidade
- Viés algorítmico e transparência nos modelos defensivos
- ISO 42001 e LLMs privados como requisito de auditabilidade

Leituras Recomendadas

- **NIST AI 100-2e2025** — Adversarial Machine Learning: A Taxonomy and Terminology
- **IBM Cost of a Data Breach 2025** — relatório completo disponível no site IBM Security
- **CrowdStrike 2026 Global Threat Report** — seção sobre AI-enabled adversaries

The background is a dark, textured surface with intricate, flowing, and swirling patterns of light gray lines. These lines create a sense of movement and depth, resembling a nebula or a complex network. Scattered throughout the background are numerous small, bright white dots and larger, soft, out-of-focus circular bokeh lights, adding to the ethereal and futuristic feel of the image.

*“Trate segurança como
cultura, não como controle.”*

Agradeço
a sua atenção!

Pedro Neves

Pedro.neves@sptech.school

(11) 99644-9239



**SÃO
PAULO
TECH
SCHOOL**